Day 4 — Asset inventory and classification

420-D04-AB Conformity Assessment

AEC Cybersecurity — LEA.D8 · cohort CYB-01 · Fall 2026
Wednesday, November 4, 2026 · 18:30–22:00 EST (online)
Lecture ≈ 60 min · then Lab 2 Part A (asset inventory)
Case company: Érable Cycles inc. (fictional) · real assets: your two lab VMs
Materials subject to the Cyber.SoHo Legal Notice v2.0 (link on the last slide)

Six rules before we start

- Everything tonight is general education about standards and laws, not legal advice; a real organization consults a lawyer and its auditor (Legal Notice, sections 8.1 and 16).
- Érable Cycles inc. and its data are fictional; the only real assets you ever inventory are your own two lab VMs (section 6.4).
- Host discovery and the collection scripts run only inside your lab environment, on your own subnet (sections 6.3, 6.4; Criminal Code s. 342.1).
- Screenshots and evidence files must not contain real personal information, credentials or addresses of other networks (section 6.7).
- Check every link before opening it — VirusTotal, Google Safe Browsing (section 14 and Annex C); every link of this page has a VT button.
- The sessions and the materials are not recorded, streamed or redistributed (section 17); standards such as **ISO** (International Organization for Standardization)/IEC 27001 and **PCI DSS** (Payment Card Industry Data Security Standard) are licensed works — cite, never copy (section 7.5); course work is not an audit of a real company.

Tonight — one hour, six lessons

- 18:30–18:45 — Recall of Day 3 — frameworks, retention minimum vs maximum, the traceability matrix, documents vs records
- 18:45–18:55 — Lesson 1 — Why assets come first: the requirements behind the inventory
- 18:55–19:05 — Lesson 2 — What counts as an asset; the twelve columns; the twelve assets of Érable Cycles
- 19:05–19:14 — Lesson 3 — Critical assets and their owners
- 19:14–19:23 — Lesson 4 — Tools: built-in commands, discovery, platforms, **CMDB** (configuration management database)
- 19:23–19:31 — Lesson 5 — Sensitivity levels, legal flags, business impact
- 19:31–19:45 — Short break
- 19:45–19:53 — Lesson 6 — Keeping the inventory current
- 19:53–22:00 — Lab 2 — Part A: asset inventory (guided 30–45 min, then individual work); finishing time Saturday; Lab 2 due Sunday November 15, 23:59 **EST** (Eastern Standard Time)

Recall of Day 3 (1/2) — frameworks

- **NIST (National Institute of Standards and Technology) CSF (Cybersecurity Framework) 2.0:** six Functions — Govern, Identify, Protect, Detect, Respond, Recover; Tiers describe governance rigour, not maturity; a Current vs Target **Profile** is itself a small conformity assessment. Tonight's category is ID.AM, in Identify.
- **ISO (International Organization for Standardization)/IEC 27001:2022:** clauses 4–10 (PDCA), Annex A with 93 controls in 4 themes (37 organizational, 8 people, 14 physical, 34 technological), the Statement of Applicability, A.5.31 behind Lab 1, A.5.37 = your Course Procedure Manual. Tonight: A.5.9, 5.10, 5.12, 5.13.
- **CIS (Center for Internet Security) Controls v8.1:** 18 Controls, 153 Safeguards; **IG1** (Implementation Group 1) = 56 Safeguards; Controls (program level) versus Benchmarks (product configuration). Tonight: Controls 1, 2 and 3.

Recall of Day 3 (2/2) — retention, matrix, documents

- **Retention:** legal minimums (**CRA** (Canada Revenue Agency) 6 years; **PCI DSS** (Payment Card Industry Data Security Standard) 10.5.1 logs 12 months with 3 online; breach records 24 months; Law 25 register 5 years) versus legal maximums (**PIPEDA** (Personal Information Protection and Electronic Documents Act) 4.5, Law 25 s. 23, **GDPR** (General Data Protection Regulation) 5(1)(e)); **PCI DSS** 3.2.1 quarterly check. Tonight the **PI** (personal information) flag tells which assets those schedules apply to.
- **Traceability matrix:** requirement → policy clause → control → evidence; three gap types — policy gap, implementation gap, evidence gap. Tonight's inventory is the evidence of **CIS** 1.1, 2.1 and **ISO** 5.9.
- **Documents vs records** and the six document-control checks: identification, version, date, approval, communication, application. Tonight the inventory itself becomes a controlled document (Lesson 6).

Lesson 1 — Why assets come first

- An assessment tests only what is listed
- Three failures without an inventory: scope errors, unowned findings, wrong protection levels
- Step 2 of the six-step method: define the scope, inventory the assets
- Tonight = Lab 2 Part A

CIS Controls v8.1 — Controls 1, 2 and 3

- 1.1 (**IG1** (Implementation Group 1)): inventory of every asset that stores or processes data — network address, hardware address, machine name, owner, department, approved to connect; review twice a year
- 1.2 (**IG1**): unauthorized assets handled weekly
- 2.1 (**IG1**): software inventory — title, publisher, install date, purpose, version; 2.2 supported only; 2.3 unauthorized software monthly
- 3.2 (**IG1**) data inventory · 3.7 (**IG2** (Implementation Group 2)) classification scheme

ISO/IEC 27001:2022 and NIST CSF 2.0

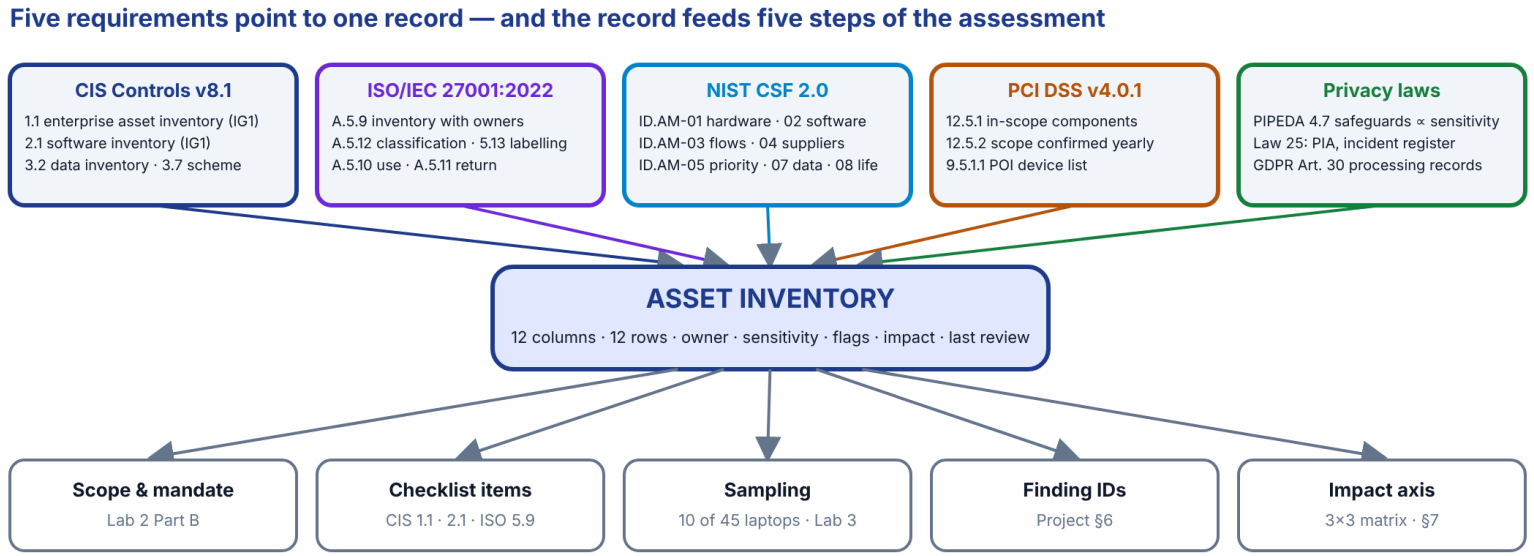
- Annex A 5.9 inventory of information and other associated assets, including owners — accurate, up to date
- 5.10 acceptable use · 5.11 return · 5.12 classification · 5.13 labelling · 5.14 transfer · 8.1 endpoint devices
- **CSF** (Cybersecurity Framework) 2.0 ID.AM-01 hardware · 02 software, services, systems · 03 flows · 04 supplier services · 05 prioritized · 07 data · 08 life cycle
- No ID.AM-06 in version 2.0

PCI DSS v4.0.1 and the privacy laws

- 12.5.1 inventory of in-scope components with their function, kept current
- 12.5.2 scope documented and confirmed every 12 months and on significant change
- 1.2.3 network diagram · 1.2.4 data-flow diagram
- 9.5.1.1 list of **POI** (point of interaction) devices: make, model, location, serial — the store terminals
- **PIPEDA** (Personal Information Protection and Electronic Documents Act) 4.7, Law 25 (**PIA** (privacy impact assessment), incident register), **GDPR** (General Data Protection Regulation) Art. 30: which systems hold personal information?

What the inventory feeds

- Scope and authorization letter (Lab 2 Part B)
- Checklist items **CIS** (Center for Internet Security) 1.1, 2.1, 3.2 — **ISO** (International Organization for Standardization) 5.9, 5.12
- Sampling: 10 of 45 laptops (Lab 3)
- Finding IDs (Project §6) and the impact axis of the 3×3 matrix (§7)
- **CPM** (Course Procedure Manual) Chapter 2: how the inventory was built



Day 4 · Lesson 1 — the inventory is step 2 of the six-step method (identify requirements → inventory assets → plan → collect evidence → analyse → report).

Example — three rows against five requirements

- SRV-DC01 complete · LT-017 no owner, no approval · POS-TERM-07 no serial, no review date
- 7 checks per asset (**POI** list only for terminals) → 15 of 19 pass = 78.9 %
- 5 missing attributes → L1_requirement_gaps.csv
- Test method for Lab 2 Part B: “inventory row present and complete”

Lesson 2 — What counts as an asset

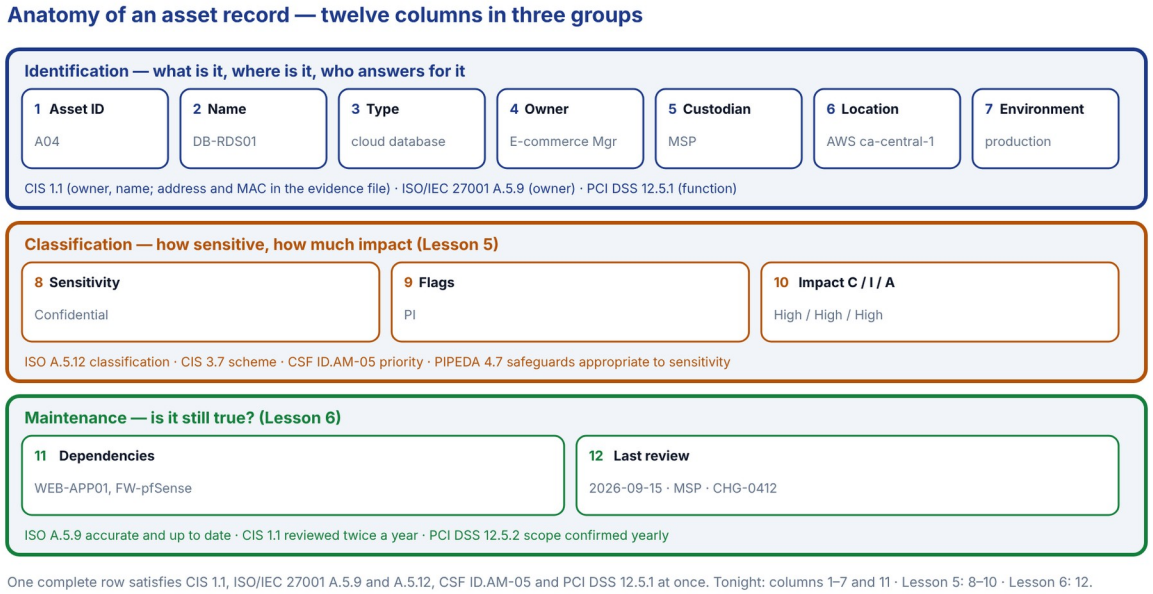
- Anything of value that an attacker, an accident or a failure could affect
- Six types: hardware · software · data · cloud / **SaaS** (software as a service) · supplier services · documents and roles
- Granularity: group identical items with one owner; separate different owners or sensitivity
- Boundary: an external service that processes our data is inside; the Internet is not

The twelve columns (1/2) — identification

- 1 Asset ID — unique, stable, never reused
- 2 Name — host or service name
- 3 Type — one of the six
- 4 Owner — accountable business role
- 5 Custodian — operates and protects
- 6 Location / hosting — site and zone, or cloud region
- 7 Environment — production, test, lab

The twelve columns (2/2) — classification and maintenance

- 8 Sensitivity — Public / Internal / Confidential / Restricted
- 9 Flags — **PI** (personal information) and **CHD** (cardholder data): which laws follow the asset
- 10 Business impact — High / Medium / Low on C, I, A
- 11 Dependencies — what it needs, what needs it
- 12 Last review — date, reviewer, change ticket
- One row satisfies **CIS** (Center for Internet Security) 1.1, **ISO** (International Organization for Standardization) 5.9 / 5.12, **CSF** (Cybersecurity Framework) ID.AM-05, PCI 12.5.1



The twelve assets of Érable Cycles

- A01 SRV-DC01 domain controller · A02 SRV-FS01 file server
- A03 WEB-APP01 (**EC2** (Elastic Compute Cloud)) · A04 DB-RDS01 (**RDS** (Relational Database Service)) · A05 Microsoft 365 tenant
- A06 **POS** (point of sale) terminals (**P2PE** (point-to-point encryption)) · A07 pfSense firewalls · A08 45 laptops · A09 NAS-BKP01
- A10 payment provider (supplier service)
- V01 LAB-WIN11 · V02 LAB-UBUNTU — the only real assets

Example — one Bash script fills the row of the Ubuntu VM

- hostname · /etc/os-release · uname -r
- ip -4 -o addr show · /sys/class/net//address
- dpkg-query -W | wc -l · ten largest packages
- systemctl list-units --type=service --state=running | wc -l
- → L2-E01_V02_linux_inventory.csv + L2-E02_V02_top10_software.txt

Lesson 3 — Critical assets come from processes

- Critical = its loss stops or seriously damages a process the organization cannot do without
- Business impact analysis: processes → impact of interruption → supporting assets → the asset inherits the impact
- Érable Cycles: online sales (H), in-store sales (H), customer communication (M), back office (M), **IT** (information technology) operations and recovery (M)
- **NIST** (National Institute of Standards and Technology) **CSF** (Cybersecurity Framework) 2.0 ID.AM-05: assets prioritized by classification, criticality, resources, mission impact

Single points of failure and dependencies

- **SPOF** (single point of failure) = a component whose failure stops a process because no alternative exists
- One domain controller · one firewall per site · one **EC2** (Elastic Compute Cloud) + one **RDS** (Relational Database Service) · one payment provider
- Redundancy removes the **SPOF** without changing the impact of the process
- Dependencies column: what the asset needs and what needs it — in both directions

Owner, custodian, user

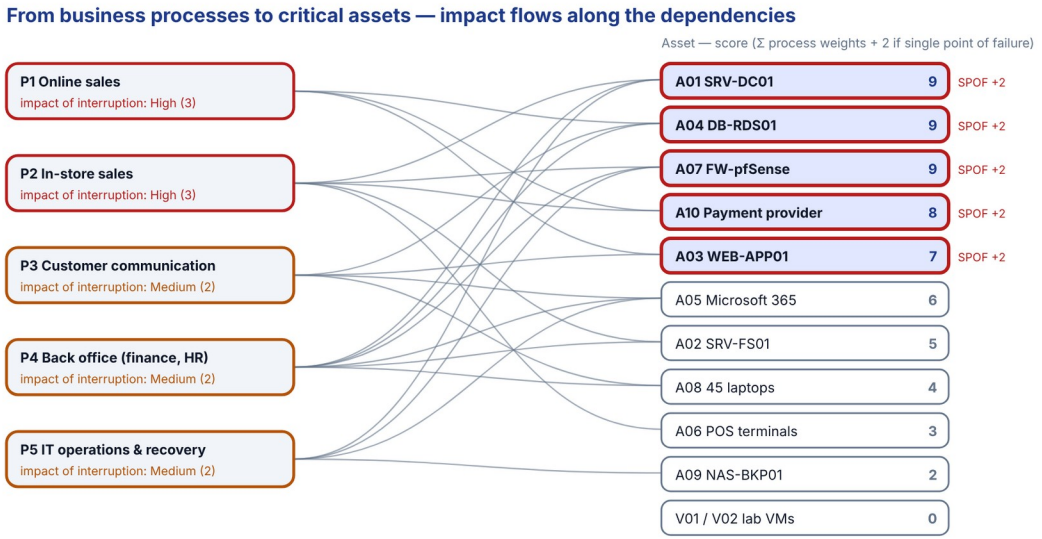
- Owner — accountable business role: classifies, approves access, sets retention, accepts risk
- Custodian — responsible for operating and protecting the asset according to the owner's decisions
- User — uses the asset for an approved purpose (**ISO** (International Organization for Standardization) 5.10 acceptable use); not a column
- Ownership ≠ legal property: the E-commerce Manager owns DB-RDS01, Amazon runs the hardware

Two frequent ownership mistakes

- **IT** as owner of everything — **IT** may own infrastructure (**DC** (domain controller), firewalls, laptop fleet), never the customer database or the finance files
- Supplier services without an owner — the contract signatory owns the relationship; the provider is the custodian
- **ISO** 5.9 and **CIS** (Center for Internet Security) 1.1 both require the owner: an empty owner cell is a finding

Example — scoring the twelve assets

- Score = Σ process weights + 2 if single point of failure
- A01 SRV-DC01 9 · A04 DB-RDS01 9 · A07 FW-pfSense 9 · A10 payment provider 8 · A03 WEB-APP01 7
- A05 Microsoft 365 6 · A02 5 · A08 4 · A06 3 · A09 2 · V01 / V02 0
- Owners may override with a written reason (the **NAS** (network-attached storage) for recovery)

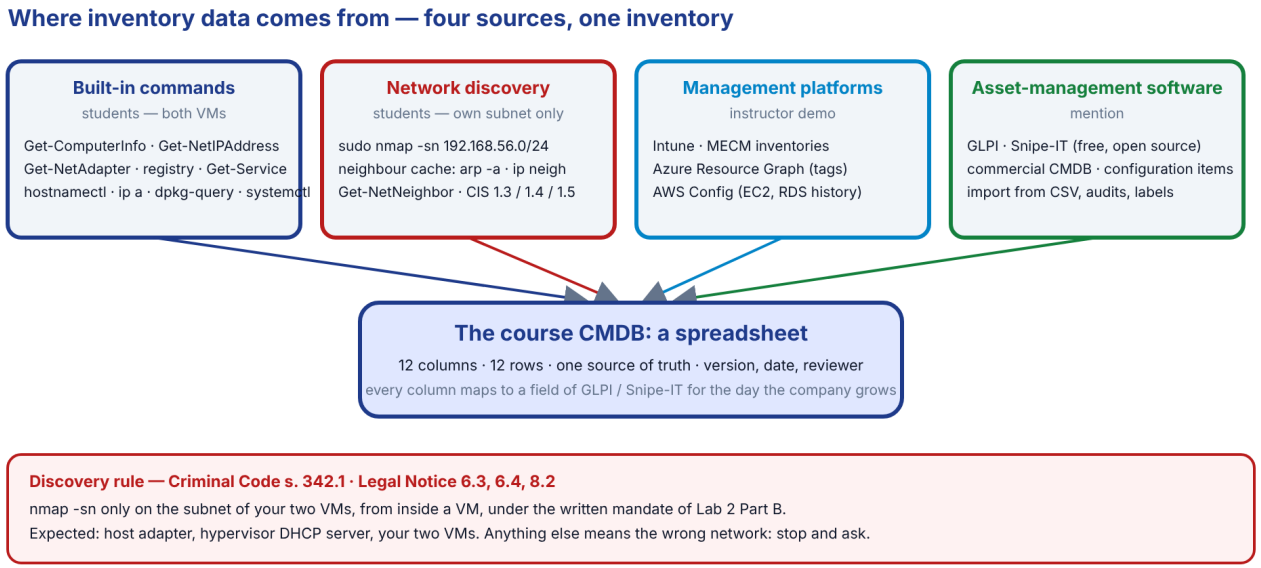


Red border = single point of failure (no redundant twin). Shaded = the five critical assets (score ≥ 7). Owners may override the ranking with a written reason.

Day 4 · Lesson 3 — NIST CSF 2.0 ID.AM-05: assets prioritized by classification, criticality, resources and impact on the mission.

Lesson 4 — Four sources of inventory data

- Built-in commands: Get-ComputerInfo, Get-NetIPAddress, registry Uninstall keys, Get-Service · hostnamectl, ip a, dpkg-query, systemctl
- Network discovery: nmap -sn, neighbour cache (arp -a, ip neigh, Get-NetNeighbor)
- Management platforms: Intune, **MECM** (Microsoft Endpoint Configuration Manager), Azure Resource Graph, **AWS** (Amazon Web Services) Config — demo only
- Asset-management software: GLPI, Snipe-IT; a **CMDB** (configuration management database) of configuration items — the course uses a spreadsheet



Day 4 · Lesson 4 — evidence = date and time + raw output file + screenshot, named L2-E0x_<asset>_<content>.

The rule for discovery

- nmap -sn sends packets to every address of a range
- Only your own lab subnet (192.168.56.0/24), from inside a **VM** (virtual machine), under the Lab 2 Part B mandate
- Expected: host adapter, hypervisor **DHCP** (Dynamic Host Configuration Protocol) server, your two VMs — three or four hosts
- Criminal Code s. 342.1 · Legal Notice 6.3, 6.4, 8.2 — anything else: stop and ask



Cheat-sheet (1/2) — identification

- Name: hostname · (Get-ComputerInfo).CsName | hostnamectl
- **OS** (operating system): Get-ComputerInfo -Property OsName, OsVersion, OsBuildNumber | /etc/os-release, uname -r
- Hardware: CsManufacturer, CsModel, BiosSeralNumber, CsTotalPhysicalMemory | lshw -short, dmidecode
- IPv4: Get-NetIPAddress -AddressFamily IPv4 | ip -4 -o addr show
- **MAC** (media access control): Get-NetAdapter | /sys/class/net//address

Cheat-sheet (2/2) — software, services, neighbours

- Software: Uninstall registry keys · winget list | dpkg-query -W · apt list --installed
- Services: Get-Service | Where Status -eq Running | systemctl list-units --type=service --state=running
- Neighbours: Get-NetNeighbor · arp -a | ip neigh · arp -a
- Discovery: sudo nmap -sn 192.168.56.0/24 (Ubuntu **VM**)
- Evidence: date and time + raw file + screenshot, named L2-E0x__

Example — the Windows VM in one PowerShell script

- Get-ComputerInfo → LAB-WIN11, Windows 11 Enterprise Evaluation build 26100, VirtualBox, 8 GB
- 192.168.56.101/24 · **MAC** 08-00-27-5B-1C-2E · 47 programs · 112 services
- Get-NetNeighbor → .1 host, .100 **DHCP**, .102 LAB-UBUNTU
- → L2-E03 inventory **CSV** (comma-separated values) · L2-E04 top-10 · L2-E05 neighbours **CSV**

Lesson 5 — Four sensitivity levels

- Public — meant for everyone; integrity still matters
- Internal — staff and contractors; minor harm
- Confidential — real harm; need-to-know; includes personal information
- Restricted — severe harm, legal consequences, compromises other assets
- **ISO** (International Organization for Standardization) 5.12 classification · 5.13 labelling · **CIS** (Center for Internet Security) 3.7 scheme · **PIPEDA** (Personal Information Protection and Electronic Documents Act) 4.7 safeguards appropriate to sensitivity — the owner decides

The two legal flags

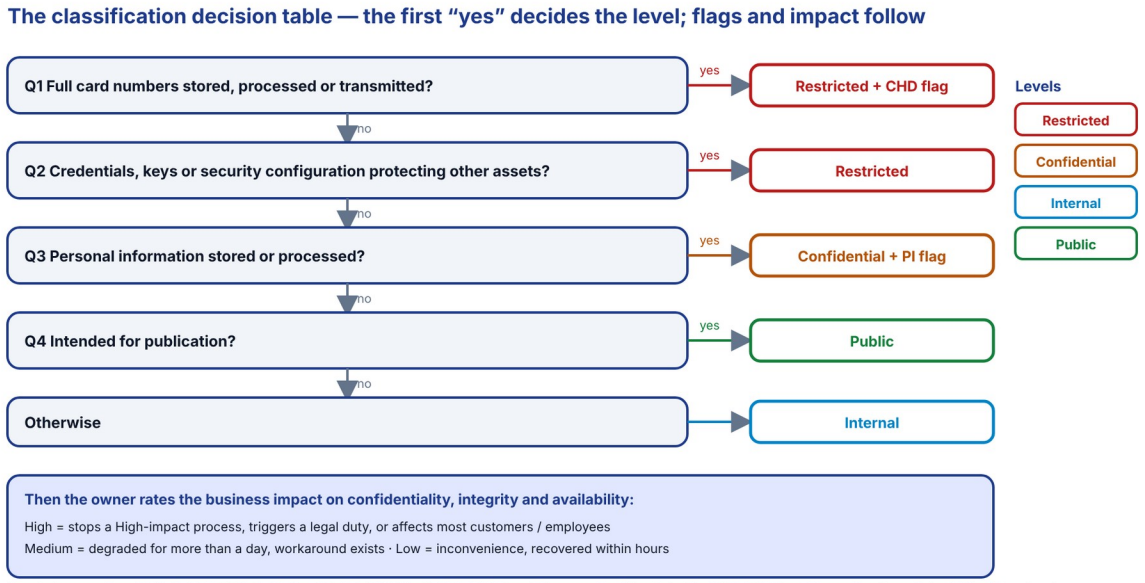
- **PI** (personal information) — personal information → **PIPEDA**, Law 25, **GDPR** (General Data Protection Regulation): **PIA** (privacy impact assessment), incident register, retention, breach duties
- **CHD** (cardholder data) — cardholder data → **PCI DSS** (Payment Card Industry Data Security Standard): inside or connected to the cardholder data environment
- At Érable Cycles: **CHD** on the **P2PE** (point-to-point encryption) terminals and the payment provider only
- Not on the web store: the hosted payment page keeps card numbers off the company's systems

Business impact on C, I and A

- High — stops a High-impact process, triggers a legal duty, or affects most customers or employees
- Medium — degrades a process for more than a day; workaround exists; few persons affected
- Low — inconvenience; recovered within hours; no external effect
- Three separate ratings per asset (FW-pfSense: H/H/H; store hours page: L/M/M)
- Feeds the impact axis of the 3×3 matrix (Lab 2 Part B)

The decision table, names and labels

- Q1 card numbers? → Restricted + **CHD** · Q2 credentials, keys, security configuration? → Restricted
- Q3 personal information? → Confidential + **PI** · Q4 published? → Public · else Internal
- First yes decides; then the owner rates C / I / A
- Naming convention SRV-DC01, LT-017, POS-TERM-07 · Purview sensitivity labels · cloud tags owner / env / data-class



Day 4 · Lesson 5 — ISO/IEC 27001 A.5.12 / 5.13 · CIS 3.7 · PIPEDA 4.7. DB-RDS01 → Q3 yes → Confidential + PI · NAS-BKP01 → Q2 yes (backup of the DC) → Restricted.

Example — the table applied to twelve assets

- Restricted 6: **DC** (domain controller), Microsoft 365, terminals, firewalls, **NAS** (network-attached storage), payment provider
- Confidential 4: file server, web server, database, laptops — all **PI**
- Internal 2: the lab VMs · Public 0
- **PI** flag on 8 assets · **CHD** flag on 2
- Edit the ASSETS array to classify your own inventory in Lab 2

Lesson 6 — One source of truth

- Finance ledger, Intune list, **MSP** (managed service provider) console, SharePoint spreadsheet — when they disagree, nobody knows
- Name one inventory; reconcile every other list against it
- Record the source of each column (Intune, **AWS** (Amazon Web Services) Config, collection scripts)
- **ISO** (International Organization for Standardization) 5.9: consistent and aligned with other inventories

Review cadence and change control

- Review = dated confirmation by a named person that each attribute is still correct
- **CIS** (Center for Internet Security) 1.1 twice a year · **PCI DSS** (Payment Card Industry Data Security Standard) 12.5.2 every 12 months and on significant change · course policy: quarterly (90 days)
- Every change carries a ticket number written in the record
- Drift = change without ticket → finding (**CIS** 2.3) · retired assets are marked, never deleted (**ISO** 5.11, 7.14)

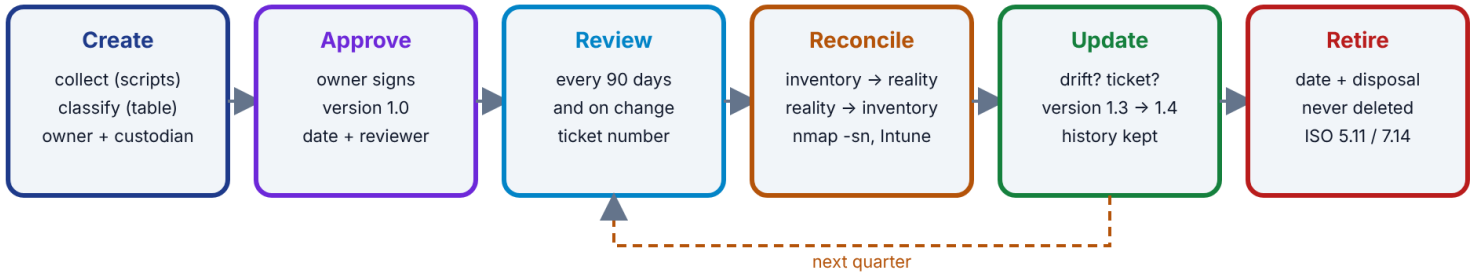
The inventory as a controlled document

- Version number changed at every review
- Date of the review · name and role of the reviewer · approval by the process owner
- Version history: what changed between 1.3 and 1.4
- The first thing the assessor reads

How the auditor tests the inventory

- Document test: version, date, reviewer, approval; review dates within the cadence
- Inventory → reality: sample three records, find the assets, check location and owner
- Reality → inventory: hosts seen by nmap -sn or Intune must have a record; otherwise unauthorized asset (**CIS** 1.2)
- Both directions = accurate (**ISO** 5.9)

The life of an inventory record — every turn produces a new version and evidence for the auditor



The auditor's three tests

1 Document test — version, date, reviewer, approval present; review dates within the cadence (CIS 1.1 twice a year · PCI DSS 12.5.2 yearly · course: 90 days)
2 Inventory → reality — sample three records, find the assets, check location and owner
3 Reality → inventory — every host seen on the network (nmap -sn, Intune) has a record, or it is an unauthorized asset (CIS 1.2)

Day 4 · Lesson 6 — one source of truth · cadence · change ticket · version stamp · drift = change without ticket.

Example — the quarterly review, automated

- Due = last review + 90 days → OK / DUE SOON (≤ 14 days) / OVERDUE
- Drift: software count changed — with ticket (documented) or without (investigate)
- Result on 2026-11-04: OK 6 · due soon 1 · overdue 5 · plan 8 items
- Version 1.3 → 1.4, reviewed by the junior analyst, next full review 2027-02-02

Lab 2 — Part A: Document IT assets (1/2)

- Inputs: the case file (the ten assets described in prose), your two VMs, the 12-column inventory template, the classification decision table and the command cheat-sheet (both in tonight's downloadables).
- Step 1 — collect: run the collection commands on both VMs (Lesson 2 script on Ubuntu, Lesson 4 script on Windows): hostname, **OS** (operating system) version and build, **IP** (Internet Protocol) and **MAC** (media access control) address, installed-software count and top 10, running services — screenshots named L2-E0x and the raw files.
- Step 2 — discover: from the Ubuntu **VM** (virtual machine): sudo nmap -sn — list the hosts that answer (expected: host adapter, hypervisor **DHCP** (Dynamic Host Configuration Protocol), your two VMs); save the output as L2-E07_nmap_sn.txt. Only your own subnet.
- Step 3 — fill the inventory: twelve rows: the ten case assets (A01–A10) and the two VMs (V01, V02); identification columns 1–7 complete.
- Step 4 — classify: apply the decision table: sensitivity level, **PI** (personal information) and **CHD** (cardholder data) flags, impact on C / I / A (Lesson 5).

Lab 2 — Part A: Document IT assets (2/2)

- Step 5 — owner and custodian: assign both roles to every row (Lesson 3); no empty owner cell.
- Step 6 — critical assets: mark five critical assets with one sentence of rationale each (processes supported, single point of failure, data held).
- Step 7 — summary and evidence: a one-page summary (method, coverage, the five critical assets, the review status and version stamp of Lesson 6) and the evidence index; optional bonus: a data-flow sketch customer → web store → payment provider → order system.
- Output: the inventory spreadsheet + the one-page summary → Project Section 4 (Scope & assets) and **CPM** (Course Procedure Manual) Chapter 2 (how to inventory and classify assets, in the 7-line skeleton).
- Rubric — Part A (5 points): inventory complete 1.5 · classification consistent with the decision table 1.5 · evidence from the VMs 1 · critical-asset rationale 1. Part B (Saturday) carries the other 5. Late work: −10 % per calendar day.



Schedule — three labs at 10 % (+ Lab 0)

- Lab 1 — laws, regulations and frameworks — Days 2–3 — due Sunday November 8, 23:59 **EST** (Eastern Standard Time)
- Lab 2 — asset inventory (Part A) + conformity assessment plan (Part B) — Days 4–6 — due Sunday November 15, 23:59 **EST**
- Lab 3 — software configuration audit (Parts A–B) + security controls verification (Part C) — Days 7–10 — due Friday November 20, 23:59 **EST**
- Project + **CPM** (Course Procedure Manual) — Conformity Assessment Report (15 %) and Course Procedure Manual (10 %) — Days 10–12 — due Tuesday November 24, 23:59 **EST**

Before 22:00 — announcements

- Homework: paste the Lab 2 Part A procedure (collection commands, decision table, review) into Chapter 2 of the Course Procedure Manual, in the 7-line skeleton.
- Lab 1 is due Sunday November 8, 23:59 EST (**PDF** (Portable Document Format) + **XLSX** (Excel Open XML spreadsheet)). Lab 0 (environment checklist) is due Tuesday November 10, 23:59 **EST**.
- Saturday November 7 (Day 5), 08:30–13:30 **EST**: conformity assessment methodologies; finish Lab 2 Part A, start Part B (the assessment plan); Practice Quiz #1 (ungraded, 15 questions in the exam format, Days 1–5).
- Mid-Term Exam: Tuesday November 10 (Day 6), 18:30 — 25 MCQ + 15 MSQ, 90 minutes, 20 %; about 6 of the 40 questions come from tonight.

Recall points for Saturday (Day 5)

- The twelve columns, and which ones are identification, classification and maintenance.
- Owner versus custodian; the two frequent ownership mistakes.
- The four sensitivity levels and the two flags; the decision table in order.
- Which frameworks demand an inventory: **CIS** (Center for Internet Security) 1.1 / 2.1 / 3.2, **ISO** (International Organization for Standardization) 5.9 / 5.12, **CSF** (Cybersecurity Framework) ID.AM, **PCI DSS** (Payment Card Industry Data Security Standard) 12.5.1 / 9.5.1.1.
- Single point of failure; why the payment provider is a critical asset.
- Cadence, drift, reconciliation in both directions.

Official links (selection)

- **CIS** Critical Security Controls v8.1
- **CIS** Control 1 — Inventory and Control of Enterprise Assets
- **ISO**/IEC 27001:2022 — Information security management systems
- **NIST** (National Institute of Standards and Technology) Cybersecurity Framework 2.0
- PCI Security Standards Council — Document Library
- **PIPEDA** (Personal Information Protection and Electronic Documents Act) — Personal Information Protection and Electronic Documents Act
- Québec — Act respecting the protection of personal information in the private sector (P-39.1, Law 25)
- **GDPR** (General Data Protection Regulation) — Regulation (**EU** (European Union)) 2016/679
- Nmap — official site and reference guide
- Microsoft Learn — Get-ComputerInfo
- Microsoft Purview — sensitivity labels
- GLPI — open-source **IT** (information technology) asset management
- Snipe-IT — open-source asset management
- Criminal Code of Canada — section 342.1 (unauthorized use of computer)

Legal notice

- Cyber.SoHo Legal Notice, Terms of Use and Acceptable Use Policy (v2.0, effective September 13, 2026)
- https://cyber-soho.github.io/prevmon/00.01.%20cyber.soho%20-%20legal.html
- Education only · fictional case · lab-only use · no real personal information in evidence · no recording or redistribution · standards are licensed works (cite, never copy) · course work is not an audit
- Cyber.SoHo Educational Hub © 2026 — From the Industry to the Classroom — Building the **IT**'s Future, Today and Together !

